

IOTA Seoul Static Bundle & IFPDP Platform Posture: PII, Backend, Hosting, Auth, and Governance Findings

This merged report consolidates the original full-disclosure findings from the deployed IOTA Seoul JavaScript bundle and extends them with red-team observations across the hosting, network, authentication, repository, and governance layers. It documents what is reachable, observable, or recoverable from the public internet by an unauthenticated visitor, and what should not be there. Authentication implemented inside a single-page application cannot protect data that has already been compiled into browser-delivered JavaScript or made world-readable by permissive Postgres Row-Level Security policies.

Prepared: 2026-05-08	Source title: IGIS Fund Production DP / IOTA Seoul
Analyzed artifacts: assets/index-D1CDWLT9.js, assets/index-DLm-CUXQ.js (current build)	Evidence handling: Full disclosure; handle as sensitive
Primary public URL: https://iotaseoul.cloud/ (canonical), https://this8369.github.io/IGIS-Fund-Production-DP/ → 301	Related public repo: this8369/IGIS-Fund-Production-DP (also: this8369/iotaseoul, this8369/igis-sono)
Backend project: https://qgrszltduzblpvpqvkqr.supabase.co	Reviewer note: All Supabase probes used in this report were read-only (HTTP HEAD/GET). No INSERT, UPDATE, or DELETE was issued against IGIS systems. Where row counts or sample fields are cited, they were obtained via anonymous SELECT using credentials freely shipped in the public JS bundle.

Executive summary. The deployed JavaScript bundle is directly downloadable by unauthenticated visitors and contains 50 internal contact records (names, IGIS emails, Korean mobile numbers, role mappings), 6 vendor / advisor contact records, project financing labels, and Supabase backend identifiers. The Supabase backend itself is reachable from anywhere on the public internet using credentials extracted from the bundle, and live probes confirm that operational tables — including a 48-row staff member table and 68-row analyst work-log table — are world-readable under the current RLS policies. Open signup with auto-confirmed email, combined with a public-update policy on the staff member table and a browser-side auth_id binding flow, creates a complete impersonation chain. Beyond the bundle leakage, the broader posture also has gaps around HTTP-to-HTTPS redirect handling, security response headers, Supabase REST CORS, GitHub account governance, domain registration, repository hygiene, and engineering practices. Each of these is documented below with evidence and a concrete remediation path.

Exposure Counts — Bundle

EMAILS 55	PHONE RECORDS 54	CONTACTS 56	INTERNAL CONTACTS 50
--------------	---------------------	----------------	-------------------------

VENDOR CONTACTS 6	ROUTES 28	EXTERNAL URLS 33	API REFERENCES 16
-----------------------------	---------------------	----------------------------	-----------------------------

Audit Summary — Findings & Verified Live Exposure

CRITICAL 7	HIGH 16	MEDIUM 11	LOW / INFO 4
TOTAL FINDINGS 38	LIVE TABLES OPEN 8+	DOMAIN AGE (DAYS) 2	REPOS AFFECTED 3

Backend Identifiers

TYPE	VALUE	RISK NOTE
Supabase project URL	https://qgrszltduzblvpqvkr.supabase.co	Identifies the backend project reachable by browser code. Once known, all standard Supabase REST, Auth, and Storage endpoints under this host are addressable from any internet client.
Supabase publishable key	sb_publishable_Gga5k7gj fXye00aEXWpew_R sCNWE mw	Publishable keys are not secrets by design, but any permissive RLS policy turns this into a practical access path. Live probes below confirm that this is currently the case.
Google Analytics property	G-QNHPD2C1K4	Loaded unconditionally on every page view including unauthenticated sessions, before any consent flow. PIPA notice/consent and cross-border data transfer concern (see H8).
Supabase auth storage key	sb-iota-auth-token	Local-storage key holding the user session. Visible in supabaseClient.js; not sensitive on its own, included for completeness.

Live Verification Evidence NEW

The following exposures were verified by issuing read-only HTTP requests to the live Supabase project from an unauthenticated client, using only the publishable key extracted from the deployed bundle. No writes, no deletes, no auth tokens. This proves the exposure is current and operational, not theoretical based on repository SQL files alone.

PROBE	RESULT	INTERPRETATION
GET /rest/v1/ iota_seoul_pilot_members	48 ROWS	Full staff directory readable: name, IGIS email, mobile phone, workspace_code, role_code, allowed_project_ids. Personal information under PIPA.
GET /rest/v1/iota_seoul_logs	68 ROWS	Operational work logs readable. raw_text field contains free-form analyst notes; presumed deal-sensitive.
GET /rest/v1/ iota_seoul_log_links	69 ROWS	Project linkage records readable.
GET /rest/v1/ iota_seoul_log_stakeholders	5 ROWS	Stakeholder mappings readable.
GET /rest/v1/ iota_workspace_kpis	1 ROW	Operational KPIs readable: covenant_status, covenant_ltv, covenant_dscr, schedule_slippage_days, budget_variance.
GET /rest/v1/ iota_building_comparison	4 ROWS	Building comparable data readable (Centerfield, 그랑서울, 파르나스타워, GFC).
GET /rest/v1/ iota_marketing_history	3 ROWS	Marketing history readable.
GET /rest/v1/ iota_building_specs / iota_research_insights	6 / 4 ROWS	Building specs and research insights readable.
OPTIONS /rest/v1/ iota_seoul_logs	GET, HEAD, POST, PUT, PATCH, DELETE ALLOWED	Methods envelope is wide open. Combined with public RLS policies in the repository SQL, write/delete by anonymous clients is the documented configuration. Not exercised in this audit.
GET /auth/v1/settings	DISABLE_SIGNUP=FALSE, MAILER_AUTOCONFIRM=TRUE	Anonymous signup is enabled and confirmation email is auto-confirmed. Forms the basis of the impersonation chain in C7.
OPTIONS Supabase REST	ACCESS-CONTROL-ALLOW-ORIGIN: *	Any origin can call this Supabase from a victim's browser. Combined with the publishable key in the bundle, malicious sites or browser extensions can scrape or tamper.

Full Internal Contact Disclosure

The values below were extracted directly from the deployed JS bundle. Rows 1–2 redact the displayed values per the source report; the remaining rows are presented as found in the bundle.

#	NAME	EMAIL	PHONE	GROUP	ROLES	RESPONSIBILITY
1	SHA-256		010-9076-5369			
2	SHA-256	jk.jeon@igisam.com				
3	우형석	hyungsuk.woo@igisam.com	010-8893-7572	CFT 총괄	사업그룹/그룹장, 전략펀드운용 1실, 사업그룹3파트/그룹장	CFT 총괄(Sub PO)
4	윤관식	gwansik.yoon@igisam.com	010-7368-0309	CFT 총괄	투자&펀딩/부대표, 투자1그룹/부대표, 투자1그룹4파트/부대표, 양재TF/TF장	CFT 총괄(Sub PO)
5	이철승	ethan.lee@igisam.com	010-3186-0868	CFT 총괄	리얼에셋부문/부문대표, 사업&개발/부문대표, 기업마케팅센터/부문대표, IOTA CFT/TF장, SMP/SMP	CFT 총괄 책임인력
6	정조민	jmjung@igisam.com	010-6341-0174	CFT 총괄	관리&운영/부대표, 리빙그룹/부대표, 전략펀드운용3실, 전략펀드운용1실, 전략펀드운용2실, 리테일솔루션센터/부대표	CFT 총괄(Sub PO)
7	윤용택	yongtek.yoon@igisam.com	010-2655-1185	IPR	사업그룹3파트/Sr.Manager, 전략펀드운용1실, 개발PFV TF, IOTA CFT	IPR 책임인력
8	김대익	dikim@igisam.com	010-9251-3466	개발관리	개발솔루션센터, IOTA CFT	
9	김보성	kbs1208@igisam.com	010-2369-2069	개발관리	개발솔루션센터, IOTA CFT	
10	박봉서	okbong21@igisam.com	010-3370-3594	개발관리	개발솔루션센터/담당, IOTA CFT	
11	이정훈	2019jhlee@igisam.com	010-4175-5799	개발관리	개발솔루션센터/담당, IOTA CFT	
12	장성진	jang.sj@igisam.com	010-9680-3293	개발관리	개발솔루션센터, IOTA CFT	
13	전승희	shjeon@igisam.com	010-3804-6529	개발관리	개발솔루션센터, IOTA CFT	
14	채원	won.chae@igisam.com	010-7222-7469	개발관리	개발솔루션센터/담당+, IOTA CFT	
15	홍장군	jghong@igisam.com	010-6229-8919	개발관리	개발솔루션센터/센터장+, IOTA CFT	개발관리 책임인력
16	고아라	argoh@igisam.com	010-4701-7725	기업마케팅	기업마케팅센터, IOTA CFT	

#	NAME	EMAIL	PHONE	GROUP	ROLES	RESPONSIBILITY
17	김민지	minjik@igisam.com	010-5454-5322	기업마케팅	기업마케팅센터/Sr.Manager, IOTA CFT	기업마케팅 책임인력
18	이관용	kylee@igisam.com	010-2927-3685	기획추진	기획추진센터, IOTA CFT	
19	이시정	sjlee@igisam.com	010-8852-9482	기획추진	기획추진센터/리더, People Architecture TF, IOTA CFT	
20	전기영	jkjeon2025@igisam.com		기획추진	기획추진센터, IOTA CFT	
21	강순용	sykang@igisam.com	010-8274-4638	사업PM	사업그룹2파트/파트장+, IOTA CFT	사업PM 책임인력
22	권순일	ksoonil@igisam.com	010-8567-6907	사업PM	사업그룹1파트/파트장+, IOTA CFT, 개발PFV TF/TF장	사업PM · IPR · 전략 자문 책임인력
23	김제익	jake.kim@igisam.com	010-5055-8197	사업PM	사업그룹1파트, IOTA CFT	
24	류홍	ryuhong0526@igisam.com	010-9081-7818	사업PM	사업그룹1파트, IOTA CFT	
25	박만진	jacob.park@igisam.com	010-4343-7438	사업PM	사업그룹1파트, IOTA CFT	
26	박석제	seokje.park@igisam.com	010-3319-9395	사업PM	사업그룹2파트, IOTA CFT	
27	박일훈	ilhoon.park@igisam.com	010-7573-6985	사업PM	사업그룹1파트, IOTA CFT	
28	박채현	p.chhyn@igisam.com	010-5095-1915	사업PM	사업그룹2파트, IOTA CFT	
29	소현준	hyunjoon.so@igisam.com	010-3857-6793	사업PM	사업그룹2파트, IOTA CFT	
30	윤주형	jh.yoon@igisam.com	010-5210-1418	사업PM	사업그룹1파트/Sr.Manager, IOTA CFT	
31	이수정	sjl1747@igisam.com	010-9222-1747	사업PM	사업그룹2파트, IOTA CFT	
32	이정원	garden.lee@igisam.com	010-3161-2931	사업PM	사업그룹1파트+, IOTA CFT	
33	전무경	mooj@igisam.com	010-2464-3709	사업PM	사업그룹1파트, IOTA CFT	
34	조영비	youngbi@igisam.com	010-2059-6511	사업PM	사업그룹2파트, IOTA CFT	
35	한수정	soojeong.han@igisam.com	010-7609-5868	사업PM	사업그룹2파트, IOTA CFT	
36	한찬호	chanho.han@igisam.com	010-4818-2108	사업PM	사업그룹2파트/Sr.Manager+, IOTA CFT	
37	김현수	hyunsoo.kim@igisam.com	010-2078-2999	상품·디지털	공간솔루션센터/센터장+, IOTA CFT	상품·디지털 책임인력

#	NAME	EMAIL	PHONE	GROUP	ROLES	RESPONSIBILITY
38	신민호	rossshin@igisam.com	010-6593-2239	상품·디지털	솔루션파트/Sr.Manager, IOTA CFT	
39	이가현	ghlee@igisam.com	010-7114-5070	상품·디지털	공간솔루션센터/리더, IOTA CFT	
40	정수명	smchung@igisam.com	010-5011-9459	상품·디지털	공간솔루션센터, IOTA CFT	
41	현철호	chyun@igisam.com	010-3368-1331	상품·디지털	디지털사업그룹/그룹장, 솔루션파트/그룹장, IOTA CFT	상품·디지털 책임인력
42	강석민	sm.kang@igisam.com	010-9091-1055	파이낸싱	Loan Finance센터/Sr.Manager, IOTA CFT	
43	김지우	jiwoo@igisam.com	010-5541-5394	파이낸싱	Loan Finance센터, IOTA CFT	
44	박준호	junhopark@igisam.com	010-9230-5400	파이낸싱	Loan Finance센터/센터장+, IOTA CFT	파이낸싱 책임인력
45	박현승	hyunpark@igisam.com	010-5376-8842	파이낸싱	Loan Finance센터, IOTA CFT	
46	손유정	yujung.son@igisam.com	010-2863-3892	파이낸싱	Loan Finance센터, IOTA CFT	
47	이성민A	stealth@igisam.com	010-3074-3396	파이낸싱	Loan Finance센터, IOTA CFT	
48	정리훈	jlh@igisam.com	010-2983-1503	파이낸싱	Loan Finance센터/Sr.Manager, IOTA CFT	
49	한승환	seunghwanhan@igisam.com	010-2722-9946	파이낸싱	Loan Finance센터, IOTA CFT	
50	김행단	hkim@igisam.com	010-2995-2352	펀드운용	국내자산관리그룹/그룹장, 자산관리2파트/그룹장, 전략펀드운용1실, IOTA CFT	펀드운용 책임인력

Full Vendor / Advisor Contact Disclosure

#	COMPANY	REPRESENTATIVE	ROLE	EMAIL	PHONE
1	KT Estate	김운영 팀장	Property Management (PM)	pm@ktestate.com	02-123-4567
2	삼일회계법인	박회계 상무	Accounting & Tax	tax@samil.com	02-333-4444
3	법무법인 태평양	이법무 변호사	Legal Advisory	legal@bkl.co.kr	02-987-6543
4	에스원 (S-1)	장보안 파트장	Facility Management (FM)	fm@s1.co.kr	02-777-8888
5	감정평가법인 A	정감정 평가사	Valuation	val@appraisal.com	02-111-2222
6	CBRE Korea	최임대 이사	Leasing Management (LM)	lm@cbre.com	02-555-6666

Exposure Categories

CATEGORY	COUNT	RISK	NOTES	SAMPLES / VALUES
Emails	55	HIGH	Direct contact identifiers embedded in the client bundle.	2019jhlee@igisam.com, argoh@igisam.com, chanho.han@igisam.com, chyun@igisam.com, dikim@igisam.com, ethan.lee@igisam.com, fm@s1.co.kr, garden.lee@igisam.com, ghlee@igisam.com, gwansik.yoon@igisam.com, hkim@igisam.com, hyungsuk.woo@igisam.com, ...
Phone numbers	54	HIGH	Mostly Korean mobile numbers plus vendor office numbers.	010-2059-6511 (조영비), 010-2078-2999 (김현수), 010-2369-2069 (김보성), 010-2464-3709 (전무경), 010-2655-1185 (윤용택), 010-2722-9946 (한승환), 010-2863-3892 (손유정), 010-2927-3685 (이관용), 010-2983-1503 (정리훈), 010-2995-2352 (김행단), 010-3074-3396 (이성민A), 010-3161-2931 (이정원), ...
Person names	74	HIGH	Named IGIS internal people plus project actors stored in UI data.	강석민, 강순용, 개발솔루션 427 담당, 개발솔루션 816 담당, 고아라, 국내 대기업 A사 (계열사 통합), 권순일, 권순일 / 강순용, 글로벌 제약사 C, 금융지주 D사, 기표 및 기존 대출 상환, 김대익, 김민지, 김보성, 김제익, 김지우, 김행단, 김현수, 대주단, 류홍, ...
Roles / departments	48	MEDIUM	Org structure and responsibility map, including CFT, PM, financing, development, marketing, fund operation.	개발솔루션센터/담당, IOTA CFT, 기업마케팅센터, 사업그룹2파트/Sr.Manager+, 디지털사업그룹/그룹장, 솔루션파트/그룹장, 개발솔루션센터, 리얼에셋부문/부문대표, 사업&개발/부문대표, 기업마케팅센터/부문대표, IOTA CFT/TF장, SMP/SMP, 사업그룹1파트+, 공간솔루션센터/리더, 투자&펀딩/부대표, 투자1그룹/부대표, 투자1그룹4파트/부대표, 양재TF/TF장, 국내자산관리그룹/그룹장, 자산관리2파트/그룹장
Vendor companies	6	MEDIUM	External partner / vendor identities and advisory roles.	감정평가법인 A, 법무법인 태평양, 삼일회계법인, 에스원 (S-1), CBRE Korea, KT Estate
Vendor representatives	6	HIGH	Named representatives for vendors / advisors.	김운영 팀장, 박회계 상무, 이범우 변호사, 장보안 파트장, 정감정 평가사, 최임대 이사
Responsibilities	10	MEDIUM	Leadership and responsibility assignments.	개발관리 책임인력, 기업마케팅 책임인력, 사업PM · IPR · 전략자문 책임인력, 사업PM 책임인력, 상품·디지털 책임인력, 파이낸싱 책임인력, 펀드운용 책임인력, CFT 총괄 책임인력, CFT 총괄(Sub PO), IPR 책임인력
Group titles	9	LOW	Internal workstream taxonomy.	개발관리, 기업마케팅, 기획추진, 사업PM, 상품·디지털, 파이낸싱, 펀드운용, CFT 총괄, IPR
Supabase project URL	1	MEDIUM	Backend project identifier is public in the bundle.	https://qgrszltduzblvpvqvkqr.supabase.co
Supabase publishable key	1	MEDIUM	Publishable keys are designed for browser use,	sb_publishable_Gga...CNWEmw

CATEGORY	COUNT	RISK	NOTES	SAMPLES / VALUES
			but database exposure depends entirely on RLS / auth policy correctness.	
Project / financing labels	1	MEDIUM	Bundle text references IOTA One/Two, PFV, REITs, LPs, lenders, bridge loans, tranche labels, shareholder loans, contractors, and tenant/workstream labels.	IOTA One 427, IOTA Two 816, Iota Project REITs, LP / 대주 / SI, 주주대여금, Tr.A-2, Tr.B-2

Project & Financing Labels — Extended EXTENDED

Labels and codes from the bundle (top block) plus additional asset and counterparty codes recovered from the public repository scripts (bottom block). All can help an attacker craft credible business-context phishing or reconstruct internal portfolio scope.

From the bundle (original report):

IOTA One 427
Iota Project REITs
IOTA Two 816
LP / 대주 / SI
Tr.A-2
Tr.B-2
주주대여금

From repo scripts (this8369/IGIS-Fund-Production-DP root, ~150 one-off scripts):

Asset codes: 421, 427, 816, 2400, IOTA, IOTA One 427, IOTA Two 816
Counterparties: NPS, Samsung, Shinhan, NH
Database scripts: check_421.py, check_2400.py, check_nps_db.py, check_nps_history.py, check_samsung_excel.py, fix_import_nh.py, query_shinhan.py, ...
Workspace codes: WS_PM, WS_MASTER, WS_FINANCING, WS_DEVELOPMENT, WS_MARKETING, WS_DIGITAL, WS_FUND, WS_IPR
Roles: master, director, manager

Domain & Hosting Posture NEW

ASPECT	OBSERVED	IMPLICATION
Canonical domain	iotaseoul.cloud	Custom domain serving the IFPDP application. github.io URL 301-redirects here.
Domain registration	Registered 2026-05-06 (1 day before this audit) at Gabia, Inc. (Korean consumer registrar). Expires 2027-05-06 (1-year registration).	Brand-new domain with no reputation history. Lookalikes (iotaseoul.com, .io, .kr, .co.kr, hyphen variants) are unregistered and can be acquired by phishing operators.
DNS	A records: 185.199.108-111.153 (GitHub Pages anycast). Nameservers: TRS-DNS / Tucows. No SPF, DMARC, or DKIM observed for the domain (no email anyway).	Hosted entirely on GitHub Pages. Any GitHub Pages outage or compromise affects the live system; no CDN or origin failover.
TLS certificate	Issuer: Let's Encrypt R13 (DV). Subject CN: iotaseoul.cloud. Validity: 2026-05-06 to 2026-08-04 (90-day cert auto-issued by GitHub Pages).	Domain Validation only — no organisational identity in the certificate. For an institutional fund manager system, OV/EV with the IGIS legal entity in the cert subject would be appropriate.
github.io → custom domain redirect	301 Location: http://iotaseoul.cloud/ (HTTP, not HTTPS).	Anyone hitting the github.io entry point is redirected over plaintext HTTP first. On hostile networks, a downgrade attack can intercept the session before HTTPS upgrade. Configure HTTPS-only redirect.
Security response headers	Missing: Strict-Transport-Security (HSTS), Content-Security-Policy, X-Content-Type-Options, X-Frame-Options / frame-ancestors, Referrer-Policy.	Site can be embedded in iframes (clickjacking), MIME-sniffed, no HSTS preload protection, referrer leaks. GitHub Pages cannot set most response headers; mitigate with <meta http-equiv> tags or terminate behind Cloudflare.
Supabase REST CORS	Access-Control-Allow-Origin: *; methods include GET, HEAD, POST, PUT, PATCH, DELETE, OPTIONS, TRACE, CONNECT.	Combined with the publishable key in the browser bundle and the open RLS policies, any other website can call this Supabase from a victim's browser. Restrict CORS to canonical origins in Supabase project → API.
Sister domain	iotaseoul.site (served by this8369/iotaseoul, "IOTA Seoul Official").	Same actor, presumed similar security posture. Larger attack surface; one compromise associates the other.
noindex directive	Present on iotaseoul.cloud (<meta name="robots" content="noindex, nofollow">). Not present on the github.io entry point that 301-redirects to it.	Search engines may index the github.io URL as a redirect; the canonical site's noindex does not propagate to the redirect source.
Production HTML cache directives	<meta http-equiv="Cache-Control" content="no-cache, no-store, must-revalidate"> in index.html. Live HTTP response actually allows cache-control: max-age=600.	Meta tags fight CDN caching but are also superseded by HTTP headers. Dev hostility carried into production HTML.

GitHub Account & Repository Posture NEW

ASPECT	OBSERVED	IMPLICATION
Account holding institutional code	Personal GitHub handle this8369. Created 2026-02-26 (~10 weeks old). No name, no bio, no company, no email, no location, 0 followers, 3 public repos.	No verifiable link between this handle and IGIS Asset Management. Bus factor: account loss or compromise locks IGIS out of its own platform code.
Repos under this account	• IGIS-Fund-Production-DP — IFPDP source, 292 KB, public. • iotaseoul — "IOTA Seoul Official" (custom domain iotaseoul.site), 255 KB, public. • igis-sono — "igis sono partnership", empty, public.	All three repositories are public. Information leak through repo names and descriptions; engineering work happens in plain view.
Commit message hygiene	Last 10+ commits on 2026-05-08 are messaged "ㅇ" (single Korean letter, no content).	No audit trail. Cannot reconstruct what changed when. Vulnerability introduction cannot be located in time.
SECURITY.md / CO DEOWNERS	Neither file exists in the IFPDP repo.	No defined responsible-disclosure path for outsiders who find issues. No required reviewers on sensitive paths (RLS, auth, PII fixtures).
Stale manual deploy script	package.json retains predeploy: npm run build and deploy: gh-pages -d dist alongside the canonical CI workflow at .github/workflows/deploy.yml.	Ad-hoc deploys from individual machines bypass CI controls.
Internal AI assistant rules in public repo	memory.md (~4 KB) names a specific user ("전기영 부장"), prescribes communication tone, names internal hierarchy ("대표이사 vs 실무진"), and documents how an AI agent should manage IGIS internal politics.	Reveals (a) an AI agent ("Antigravity") is doing the actual development work, (b) named internal staff and reporting dynamics, (c) a behavioural profile of the human user.
Backup & WIP files committed to main	temp.jsx (53 KB), temp_groups.cjs (19 KB, contains staff PII), Section7.jsx.bak, index_backup.html (62 KB).	History pollution; bundle bloat if any are imported; reverse-engineering surface; PII in backup file.
Root-level script soup	~150 root-level files: check_*.py (~50), fix_*.py (~20), query_*.py (~15), test_*.py, js, mjs, cjs (~20), patch_*.cjs, read_*.py, update_*.py.	Reveals data structure, asset codes (421, 427, 816, 2400, NPS, Samsung, Shinhan, NH, IOTA), and database evolution to anyone reading. Pollutes the build context.
UI patching style	20+ fix_scroll_*.py variants, replace_chat.py, replace_iotatwo.py, replace_nav.py, revert.py (14 KB), and 2026-05-08 commits added patch_workspace_pm.py, patch_workspace_pm2.py, patch_workspace_pm3.py, patch_workspaces.py.	Engineering fragility. revert.py indicates a rollback loop. UI changes by Python find/replace will keep generating fragile state.
.DS_Store tracked		Hygiene only; file is harmless in itself.

ASPECT	OBSERVED	IMPLICATION
	Repo root has .DS_Store (18 KB). .gitignore excludes it but the file is a stale tracked entry.	
RLS regression test script	check_rls.js calls supabase.rpc('get_policies'). No such RPC is defined in the reviewed SQL.	Self-check is non-functional. Gives false confidence that RLS was checked.
Supabase client fallback	src/utils/supabaseClient.js:3-4: 'https://dummy-url.supabase.co', 'dummy-key'.	Misconfigured builds silently ship; the failure mode that matters most is hidden.

Critical & High Findings

Findings labelled **C1–C6, H1–H9** were carried forward from the original full-disclosure report. Findings labelled **C7, H10–H16** are added in this merged report.

ID	FINDING	EVIDENCE	PREVENTION / FIX
C1	RLS policies on operational tables permit anonymous SELECT, INSERT, UPDATE, and DELETE	• <code>kpis_setup.sql:21–23</code>; <code>pilot_form_setup.sql:47–61</code>; <code>enable_delete_policy.sql</code>; <code>enable_delete_policy_v2.sql</code>. • Affected operational tables: <code>iota_workspace_kpis</code>, <code>iota_seoul_pilot_members</code>, <code>iota_seoul_logs</code>, <code>iota_seoul_log_links</code>, <code>iota_seoul_log_stakeholders</code>. • Most <code>iota_two_816_setup.sql</code> tables are SELECT-only by comparison; logs / KPIs / members are wide open. • Live verification (this audit): 48 staff rows, 68 log rows, 69 link rows, 5 stakeholder rows, 1 KPI row readable anonymously.	• Drop the USING (true) policies on operational tables. • Grant SELECT only to authenticated users scoped by workspace membership, <code>allowed_project_ids</code>, or <code>role_code</code> — not just <code>auth.uid()</code> IS NOT NULL. • Use WITH CHECK predicates on INSERT / UPDATE so users cannot insert rows for other workspaces or escalate their own role. • Move admin and import paths to <code>service_role</code> invoked from a backend or Edge Function, not from the browser. • Make DELETE <code>service_role</code> only by default; reconsider any anonymous DELETE path. • For genuinely public reference data, keep SELECT open but split it into a clearly named public schema so the boundary is obvious.
C2	Supabase anon key committed in .env and bundled into deployed JS via VITE_* prefix	• <code>.env</code> tracked on main; <code>.gitignore:9–12</code> does not list <code>.env</code>. • <code>src/utils/supabaseClient.js:3–4</code> reads <code>VITE_SUPABASE_URL</code> / <code>VITE_SUPABASE_ANON_KEY</code>. • Vite bakes <code>VITE_*</code> values into the browser bundle. • <code>.github/workflows/deploy.yml:32–34</code> injects Supabase values at build from CI secrets.	• Rotate the anon key. • Ensure CI secrets hold the new key. • Remove <code>.env</code> from the working tree with <code>git rm --cached .env</code>. • Add <code>.env*</code> to <code>.gitignore</code>. • Consider history rewrite if the prior key was used against permissive RLS for any meaningful window. • Treat the bundled anon key as public going forward. Protection is RLS, not key secrecy.
C3	Personal information for IGIS staff committed to public Git, including phone numbers	• <code>setup.sql:28–74</code> inserts 45+ staff names, emails, and organisational roles as seed data. • <code>setup.sql:24–25</code> creates a SELECT policy using USING (true). • <code>temp_groups.cjs:9–11</code> and similar repeated entries contain staff names, emails, and Korean mobile phone numbers in <code>010-XXXX-XXXX</code> format. • Bundle artefact <code>index-D1CDWLT9.js</code> additionally embeds 50 internal contacts in client-delivered JavaScript.	• Purge the affected files from current main by deleting or redacting the personal data. • Purge the same data from Git history using <code>git filter-repo</code> or BFG. • Notify the IGIS legal / compliance owner so PIPA notice / notification thresholds can be assessed by counsel. • Audit Supabase access logs for unauthenticated reads against <code>iota_seoul_pilot_members</code> since the public SELECT policy was created. • Run this as C-priority work in parallel with C1, not after C1.

ID	FINDING	EVIDENCE	PREVENTION / FIX
C4	iota_seoul_logs.raw_text is anon-readable, anon-writable, and anon-deletable	• pilot_form_setup.sql:12 defines raw_text TEXT. • pilot_form_setup.sql:47-49 opens public SELECT, INSERT, and UPDATE. • enable_delete_policy_v2.sql:2-5 adds public DELETE. • Live: 68 rows readable anonymously; OPTIONS shows the table accepts GET, HEAD, POST, PUT, PATCH, DELETE.	• Tighten policies per C1 immediately. • Run a one-time integrity audit before further use: row counts versus expected, creation timestamp distribution, and writer_staff_id values that do not match iota_seoul_pilot_members. • Add an immutable append-only audit table for log lifecycle events: creates, updates, deletes, actor, IP, and request id. • Apply PII redaction at write time before any AI ingestion, while treating redaction as secondary to first locking writes.
C5	Hardcoded PILOT_ACCESS_CODE = 'IOTA2026' in browser bundle as a gate	• src/components/system/AuthSetup.jsx:21 defines const PILOT_ACCESS_CODE = 'IOTA2026'. • grep IOTA2026 against https://iotaseoul.cloud/assets/index-DLm-CUXQ.js returns the literal.	• Remove the constant from client code. • Replace it with admin-issued, single-use invite codes per member. • Validate invite codes server-side in an Edge Function or backend, not in the browser. • Move auth_id binding into a server function that validates invite, email, and member record together. • Remove public-update policy from iota_seoul_pilot_members.
C6	Real fund / asset metrics labelled as mock data committed to a public repo	• src/data/mockAssetDB.js:1-60+ contains The-K Twin Towers (더케이타워), fund vehicle 389호, named director 정영진 and PM 장민호. • The same file includes AUM 985 billion KRW, IRR 122.11%, occupancy 99%, exit date 2024-08-30, and tenant references including 카카오 and LG. • The schema layout matches the real IFPDP_Asset_DB_Schema.csv taxonomy.	• Confirm with the investment team whether the figures are real, redacted, or synthetic. • If real or recognisable, redact and purge from Git history. • Treat confirmed real or recognisable figures as a confidential business data incident. • For future synthetic seed data, use clearly fake names and numbers. • Add a file-header watermark stating that synthetic fixtures are fictional and contain no real company, asset, person, or transaction data.

ID	FINDING	EVIDENCE	PREVENTION / FIX
C7	Open signup + auto-confirmed email + browser-side auth_id binding form a complete staff-impersonation chain NEW	• Live: GET /auth/v1/settings returns "disable_signup":false, "mailer_autoconfirm":true. • Public-update RLS on iota_seoul_pilot_members (per C1, verified live with 48 rows readable). • First-time-signup auth_id binding flow in AuthSetup.jsx performs the binding from the browser without server-side validation.	• Disable signup, or set mailer_autoc onfirm: false and require an explicit verification step. • Move auth_id binding into a server-side Edge Function that validates an admin-issued, single-use invite per member. • Pair with the C1 RLS fix and the C5 invite-code fix; the chain only closes when all three are addressed. • Audit Supabase auth logs for any unexpected sign-ups, especially from non-IGIS email domains.
H1	Client-side route guard treated as authorisation	• src/App.jsx:83–89 redirects unauthenticated users away from / platform/iotaseoul routes. • Direct Supabase REST calls bypass the route guard entirely.	• Treat client-side guards as UX only. • Use RLS as the actual authorisation boundary. • Enforce privacy on every data fetch through RLS policies, not through routing.
H2	Plaintext password or generated credential rendered into the DOM in the AuthSetup confirmation modal	• AuthSetup.jsx confirmation / password modal. • Full file is large; verify exact line references before sharing externally.	• Never render secrets back to the screen. • If the user needs to confirm a password, validate without re-display. • Deliver generated credentials through a secure channel such as a one-time email link or admin invite flow.
H3	SQL setup scripts use DROP TABLE IF EXISTS at the top of every file	• setup.sql:4; kpis_setup.sql:4; iota_two_816_setup.sql:5; pilot_form_setup.sql uses the same pattern. • Recent commits include fix_migration.py and revert_migration.py — suggesting this has already been a problem.	• Convert setup scripts to versioned, idempotent migrations. • Use CREATE TABLE IF NOT EXISTS and ALTER TABLE ... ADD COLUMN IF NOT EXISTS where appropriate. • Adopt a migration tool such as Supabase CLI migrations or sqitch. • Require service_role or similarly privileged execution for migrations.
H4	No history on dynamic fields; KPI changes overwrite prior values	• iota_workspace_kpis in kpis_setup.sql:6–17 has updated_at only.	• Add a KPI history table populated by Postgres trigger. • Capture asset_id, field, old_value, new_value, effective_date, reporting_period, source_doc_id, recorded_by, and approval_state. • Treat database-mutation history and investment-effective history as different concepts; triggers capture only the easier half. • Add effective dating for production-grade analytics.
H5	No provenance on dynamic values	• No source_doc_id, source_section, recorded_by, or confidence columns on iota_workspace_kpis or related KPI tables.	• Add a source_documents table. • Add a foreign key from KPI rows to source_documents.

ID	FINDING	EVIDENCE	PREVENTION / FIX
			• Add recorded_by referencing auth.users. • Add confidence as a bounded numeric field. • Make provenance required and non-null for material KPI writes once the supporting table exists.
H6	No audit log of writes, and ideally reads, on operational tables	• No audit_* tables in reviewed SQL. • Operational tables have updated_at only.	• Add trigger-based audit tables for writes. • Record actor, IP, request id, operation type, old value, new value, and timestamp. • Make audit tables append-only. • Use PGAudit or Supabase logs for SELECT auditing only on scoped high-risk tables — read auditing is heavier and noisier.
H7	RLS regression tests do not exist	• package.json:6–13 has no test script. • check_rls.js:17–18 calls rpc('get_policies'), but no such RPC is defined in the reviewed SQL — the existing self-check is non-functional.	• Add Vitest. • Write tests proving unauthenticated clients cannot SELECT, INSERT, UPDATE, or DELETE private rows. • Write tests proving wrong-workspace authenticated clients cannot access rows outside their scope. • Run the RLS regression suite in CI on every push.
H8	Google Analytics and Google Fonts load before authentication or consent on a noindex pre-launch site	• index.html:13–14 marks the site noindex. • index.html:25–43 loads Google Fonts and gtag('config', 'G-QNHPD2C1K4').	• Remove Google Analytics until launch with a proper notice / consent flow. • Alternatively load analytics only after authenticated consent. • Self-host Pretendard and Inter instead of loading Google Fonts from a third party. • Document third-party data transfer and retention posture before enabling analytics.
H9	GitHub Pages base-path mismatch between Vite config and 404 SPA shim	• vite.config.js:7 sets base: '/'. • public/404.html:8 sets var segmentCount = 0 for a custom-domain root. • src/App.jsx:16 comment references '/IGIS-Fund-Production-DP/' in GitHub Pages production.	• Confirm the actual deployed URL first. • If using project Pages, set Vite base to '/IGIS-Fund-Production-DP/' for builds. • If using project Pages, set segmentCount = 1 in public/404.html. • If using a custom domain root (current state: iotaseoul.cloud), the current configuration is correct.
H10	github.io entry point redirects over HTTP, not HTTPS NEW	• curl -I https://this8369.github.io/IGIS-Fund-Production-DP/ returns 301 Location: http://iotaseoul.cloud/.	• Configure the redirect target as https://iotaseoul.cloud/. • Enable "Enforce HTTPS" on both Pages-publishing repos.

ID	FINDING	EVIDENCE	PREVENTION / FIX
			• Add an HSTS preload-eligible header via <code><meta http-equiv></code> on the canonical site.
H11	No security response headers on <code>iotaseoul.cloud</code> NEW	• Live HTTP response missing: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options / frame-ancestors, Referrer-Policy. • Access-Control-Allow-Origin: * on the static origin (acceptable for static, but combined with H12 is more concerning).	• Add <code><meta http-equiv="Content-Security-Policy"></code> and Referrer-Policy in <code>index.html</code>. • Set <code>frame-ancestors 'none'</code> in CSP to prevent clickjacking. • For full HTTP-header enforcement, terminate behind Cloudflare or a similar proxy in front of GitHub Pages.
H12	Supabase REST API CORS is Access-Control-Allow-Origin: * NEW	• Live OPTIONS response from the Supabase REST endpoints returns wildcard CORS plus <code>access-control-allow-methods: GET, HEAD, PUT, PATCH, POST, DELETE, OPTIONS, TRACE, CONNECT</code>.	• Restrict CORS to <code>https://iotaseoul.cloud</code> (and any staging origin) in Supabase project → API settings. • Pair with C1: even with CORS open, RLS should prevent cross-origin data leakage.
H13	Anonymous-style GitHub account holds all institutional code NEW	• Account <code>this8369</code> created 2026-02-26 (~10 weeks old). • No name, no bio, no company, no email, no location, 0 followers. • Holds three public repos: IGIS-Fund-Production-DP, <code>iotaseoul</code>, <code>igis-sono</code>.	• Move all repos into a verified GitHub Organisation tied to the <code>igisam.com</code> domain. • Add named owners with 2FA enforcement. • Add CODEOWNERS requiring reviewers for sensitive paths (RLS, auth, PII fixtures). • Add SECURITY.md with a defined responsible-disclosure path.
H14	Brand-new domain on a consumer Korean registrar with no organisational verification NEW	• WHOIS for <code>iotaseoul.cloud</code>: created 2026-05-06 at Gabia, Inc., 1-year registration. • TLS via Let's Encrypt 90-day DV certificate (auto-issued through GitHub Pages). • No EV / OV cert; no organisational WHOIS tying the domain to IGIS Asset Management. • No defensive registrations of obvious lookalikes (<code>.com</code>, <code>.io</code>, <code>.kr</code>, <code>.co.kr</code>, hyphen variants).	• Move the registration into IGIS's corporate registrar account. • Register defensive lookalikes (<code>.com</code>, <code>.io</code>, <code>.kr</code>, <code>.co.kr</code>, hyphen variants). • Consider an OV / EV TLS certificate so the IGIS legal entity appears in the certificate subject.
H15	Two parallel custom domains under the same anonymous account NEW	• <code>this8369/iotaseoul</code> Pages-redirects to <code>https://iotaseoul.site/</code>. • Same owner, presumed similar security posture (not verified to the same depth in this audit).	• Decide which is canonical and harden both to the same standard, or retire one cleanly. • Cross-link both sites so users do not get confused which is canonical IFPDP.
H16	Service-role boundary unclear; admin / import paths likely run from local laptops against the same	• Repository contains 100+ <code>admin / import</code> scripts (<code>import_crm_data*.py</code>, <code>update*.py</code>, <code>fix*.py</code>, <code>query*.py</code>) that hit the database directly.	• All admin paths through a backend / Edge Function using a service-role key on the server side.

ID	FINDING	EVIDENCE	PREVENTION / FIX
	publicly-writable tables NEW	• The bundle contains a publishable key, not a service-role key. • Either admin operations rely on the same wide-open RLS as exposed users, or developers carry a service-role key in private .env files run from individual machines.	• Service-role key never enters a browser bundle, a git repo, or a developer laptop's local script. • Add audit logging for admin operations: who ran what, when, against which rows.

Medium Findings NEW

ID	FINDING	EVIDENCE	PREVENTION / FIX
M1	Commit message hygiene — last 10+ commits are "ㅇ"	gh api repos/this8369/IGIS-Fund-Production-DP/commits shows every commit on 2026-05-08 with message "ㅇ" — single Korean letter, no content. No traceable history of what changed when.	Adopt Conventional Commits or any structured message format. Enforce via PR template or pre-push hook. Vulnerability introduction should always be locatable in time.
M2	UI patched via Python find/replace scripts	20+ fix_scroll_*.py variants, replace_chat.py, replace_iotatwo.py, replace_nav.py, revert.py (14 KB). Today's commits added patch_workspace_pm.py, patch_workspace_pm2.py, patch_workspace_pm3.py, patch_workspaces.py.	UI changes belong in components, in PRs, with tests. revert.py should not be a workflow. Phase out script-based UI mutation before more code is built this way.
M3	Supabase client silently falls back to dummy values	src/utils/supabaseClient.js:3-4 — 'https://dummy-url.supabase.co', 'dummy-key'. Misconfigured builds silently ship.	Hard throw on missing env. Make the failure mode loud where it matters most.
M4	Internal AI assistant rules in memory.md leak human and political detail	Public-repo file names a specific user ("전기영 부장"), prescribes communication tone, names internal hierarchy ("대표이사 vs 실무진"), and documents how an AI agent should manage IGIS internal politics. Reveals (a) an AI agent ("Antigravity") does the development, (b) named internal staff and reporting dynamics, (c) a behavioural profile of the human user.	Remove from public repo. Move to a private memory store or env-based config. If kept in repo, redact names and political framing.
M5	Stale manual deploy script in package.json alongside CI workflow	package.json:11-12 — predeploy: npm run build, deploy: gh-pages -d dist. .github/workflows/deploy.yml is the canonical deploy.	Remove the manual gh-pages script from package.json to prevent ad-hoc deploys from individual machines.
M6	No least-privilege GRANT / REVOKE paired with RLS	All reviewed SQL files rely entirely on RLS without explicit table-level grants. RLS misconfiguration collapses straight to default privileges.	Pair every RLS policy block with explicit grants: REVOKE ALL ON public.<table> FROM public; GRANT SELECT ON public.<table> TO authenticated; etc.
M7	Backup & WIP files committed to main	temp.jsx (53 KB), temp_groups.cjs (19 KB; also containing PII per C3), Section7.jsx.bak, index_backup.html (62 KB).	Remove from git. Add .bak, *_backup.*, temp*. {jsx, cjs, js} patterns to .gitignore.
M8	Root-level script soup reveals additional asset codes beyond what is in the bundle	~150 root-level scripts include check_421.py, check_2400.py, check_nps_*.py (x7), check_samsung_*.py, query_shinhan.py, fix_import_nh.py. External readers learn deal / fund codes that may not be intended public.	Move all under scripts/. Consolidate iterative duplicates (e.g. import_crm_data.py through import_crm_data4.py). Treat asset codes as confidential where appropriate.
M9			

ID	FINDING	EVIDENCE	PREVENTION / FIX
	.DS_Store tracked despite .gitignore excluding it	Repo root has .DS_Store (18 KB); .gitignore excludes it. Stale tracked entry.	git rm --cached .DS_Store and commit.
M10	Production HTML carries dev Cache-Control meta tags	index.html:5-7 — three meta tags. Live HTTP response has cache-control: max-age=600, so the meta is being ignored, but it should not be in production HTML.	Remove the meta tags from index.html. Real cache control on GitHub Pages comes from hashed asset filenames.
M11	Massive single-file components	Notes.jsx 87 KB, Header.jsx 45 KB, Section13.jsx 26 KB, Section4.jsx 23 KB.	Mechanical split into subcomponents. Lower priority than security work, but compounds maintenance cost over time.

Low / Informational Findings NEW

ID	FINDING	EVIDENCE	PREVENTION / FIX
L1	github.io URL itself is not on noindex	The noindex meta is on iotaseoul.cloud, not on the github.io entry point that 301-redirects to it. Search engines may index the redirect.	Publish a noindex page from the github.io Pages too, or remove the github.io publish if iotaseoul.cloud is canonical.
L2	this8369/igis-sono repo description signals an unfinished partnership	Empty repo, but the name and description ("igis sono partnership") signal an early or planned partnership project to anyone watching the account.	Delete or privatise unused repos. Treat repo names as public information leaks.
L3	No SECURITY.md, no CODEOWNERS	Neither file exists in the IFPDP repo. No defined responsible-disclosure path; no required reviewers on sensitive paths.	Add SECURITY.md with a security contact email or PGP. Add CODEOWNERS requiring named reviewers on RLS, auth, fixtures, and migrations.
L4	Sister repo this8369/iotaseoul ships the same script-soup pattern	20+ fix_*.py files at root, .DS_Store tracked, similar deployment style. Implies the same security posture issues that iotaseoul.cloud has likely apply to iotaseoul.site too.	Apply identical hardening to both, or sunset one. Avoid running two parallel platforms with the same posture.

External URLs Present in Bundle

#	URL
1	http://localhost:9999
2	http://www.w3.org/1998/Math/MathML
3	http://www.w3.org/1999/xlink
4	http://www.w3.org/2000/svg
5	http://www.w3.org/XML/1998/namespace
6	https://270parkave.com/
7	https://a16z.com/podcast/a16z-podcast-data-network-effects/
8	https://bankersmagazine.com/ai-banking/articles/goldman-ai-architecture/
9	https://developer.mozilla.org/en-US/docs/Web/API/LockManager/request
10	https://eqtgroup.com/about/motherbrain
11	https://github.com/orgs/supabase/discussions/37217
12	https://gpt4all.io/
13	https://hbr.org/2017/05/whats-your-data-strategy
14	https://hbr.org/2025/12/why-your-company-needs-a-chief-data-analytics-and-ai-officer
15	https://iotaseoul.site/
16	https://qgrszltduzblvpqvkqr.supabase.co
17	https://react.dev/errors/
18	https://useanything.com/
19	https://www.aboutamazon.com/news/company-news/amazons-original-1997-letter-to-shareholders
20	https://www.altusgroup.com/insights/commercial-real-estate-data-integration/?utm_source=google&utm_medium=organic
21	https://www.bcg.com/publications/2026/how-leaders-build-an-ai-first-cost-advantage
22	https://www.brookfield.com/views-news/insights/next-industrials-ai-transformation#driving-results
23	https://www.economist.com/leaders/2017/05/06/the-worlds-most-valuable-resource-is-no-longer-oil-but-data
24	https://www.facebook.com/jll/videos/jll-falcon/1544548580080896/
25	https://www.google.com/search?q=NanoClaw+AI
26	https://www.google.com/search?q=Nanobot+AI
27	https://www.google.com/search?q=NemoClaw+AI

#	URL
28	https://www.linkedin.com/mcas.ms/in/seggar
29	https://www.linkedin.com/pulse/ai-skills-gap-training-programme-closing-indhran-seghar-gk0hc/
30	https://www.linkedin.com/pulse/your-ai-agent-just-deleted-database-didnt-make-single-indhran-seghar-z08sc/
31	https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-data-driven-enterprise-of-2025
32	https://www.mckinsey.com/midwest/~/_media/McKinsey/Business%20Functions/McKinsey%20Analytics/Our%20Insights/Why%20data%20culture%20matters/Why-data-culture-matters.pdf
33	https://www.weforum.org/stories/2018/01/data-is-not-the-new-oil/

Representative Source Evidence

Excerpts from assets/index-D1CDWLT9.js. They prove the values are embedded in browser-delivered JavaScript rather than fetched only after authorisation.

#	NAME / COMPANY	EMAIL	PHONE	BUNDLE EXCERPT
1	SHA-256		010-9076-5369	a2 2 0 00-2 2v10a2 2 0 002 2z"}}}}),e.jsx("h3", {className:"text-[22px] font-bold ...","children":"플랫폼 이용 문의"}...
2	SHA-256	jk.jeon@igisam.com		5 19h14a2 2 0 002-2V7a2 2 0 00-2-2H5a2 2 0 00-2 2v10a2 2 0 002 2z"}}}}),e.jsx("h3",...
3	김운영 팀장	pm@ktestate.com	02-123-4567	{"company":"KT Estate","role":"Property Management (PM)","rep":"김운영 팀장","contact":"02-123-4567","email":"pm@ktestate.com","status":"계약 유지중"...
4	박회계 상무	tax@samil.com	02-333-4444	{"company":"삼일회계법인","role":"Accounting & Tax","rep":"박회계 상무","contact":"02-333-4444","email":"tax@samil.com","status":"세무 실사 중"...
5	이법무 변호사	legal@bkl.co.kr	02-987-6543	{"company":"법무법인 태평양","role":"Legal Advisory","rep":"이법무 변호사","contact":"02-987-6543","email":"legal@bkl.co.kr","status":"자문 계약 체결"...
6	장보안 파트장	fm@s1.co.kr	02-777-8888	{"company":"에스원 (S-1)","role":"Facility Management (FM)","rep":"장보안 파트장","contact":"02-777-8888","email":"fm@s1.co.kr","status":"우선협상대상자"...
7	최임대 이사	lm@cbre.com	02-555-6666	{"company":"CBRE Korea","role":"Leasing Management (LM)","rep":"최임대 이사","contact":"02-555-6666","email":"lm@cbre.com","status":"전속 대행 계약"...
8	이철승		010-3186-0868	{"groupTitle":"CFT 총괄","members":[{"name":"이철승","photo":"이철승","roles":["리얼에셋부문/부문대

#	NAME / COMPANY	EMAIL	PHONE	BUNDLE EXCERPT
		ethan.lee@igisam.com		표",...],"responsibility":"CFT 총괄 책임인력","email":"ethan.lee@igisam.com","phone":"010-3186-0868"}...
9	윤관식	gwansik.yoon@igisam.com	010-7368-0309	{"name":"윤관식","photo":"윤관식","roles":["투자&펀딩/부대표","투자1그룹/부대표",...],"responsibility":"CFT 총괄(Sub P0)","email":"gwansik.yoon@igisam.com","phone":"010-7368-0309"}...
10	정조민	jmjung@igisam.com	010-6341-0174	{"name":"정조민","photo":"정조민","roles":["관리&운영/부대표","리빙그룹/부대표",...],"responsibility":"CFT 총괄(Sub P0)","email":"jmjung@igisam.com","phone":"010-6341-0174"}...
11	김행단	hkim@igisam.com	010-2995-2352	{"groupTitle":"펀드운용","members":[{"name":"김행단","photo":"김행단","roles":["국내자산관리그룹/그룹장","자산관리2파트/그룹장","전략펀드운용1실","IOTA CFT"],"responsibility":"펀드운용 책임인력","email":"hkim@igisam.com","phone":"010-2995-2352"}]...
12	홍장군	jghong@igisam.com	010-6229-8919	{"groupTitle":"개발관리","members":[{"name":"홍장군","photo":"홍장군","roles":["개발솔루션센터/센터장+","IOTA CFT"],"responsibility":"개발관리 책임인력","email":"jghong@igisam.com","phone":"010-6229-8919"}]...

Immediate Remediation

Run these in this order. Items 1–4 are the actual blast-radius limiters; everything else is conditional on them.

1. **Lock the database.** Drop every USING (true) policy on operational tables (iota_seoul_pilot_members, iota_seoul_logs, iota_seoul_log_links, iota_seoul_log_stakeholders, iota_workspace_kpis). Replace with workspace-scoped, role-aware authenticated policies using WITH CHECK predicates. (C1.)
2. **Close the auth chain.** Set disable_signup: true or mailer_autoconfirm: false. Move auth_id binding to a server-side Edge Function with admin-issued, single-use invite codes. (C5, C7.)
3. **Lock CORS on Supabase.** Restrict Access-Control-Allow-Origin to canonical origins only. (H12.)
4. **Purge personal information from Git history.** .env, the staff INSERT blocks in setup.sql, temp_groups.cjs, index_backup.html. Use git filter-repo or BFG. Force-push and ask GitHub Support to invalidate cached forks if any exist. (C2, C3.)
5. **Compliance review.** Notify the IGIS legal / compliance owner. PIPA notice / notification thresholds are a legal call, especially because mobile phone numbers were involved. (C3.)
6. **Confirm mockAssetDB.js is synthetic.** If real, redact and purge from history; treat as a confidential business data incident. (C6.)
7. **HTTPS-only redirects + HSTS.** Configure the github.io entry to redirect to https:// and enforce HTTPS on both Pages-publishing repos. (H10.)
8. **Remove or gate Google Analytics + Google Fonts.** Either remove until launch with a proper notice / consent flow, or self-host Pretendard / Inter and load GA only after authenticated consent. (H8.)
9. **Move repos into a verified IGIS GitHub Organisation.** Named owners, 2FA enforcement, CODEOWNERS, SECURITY.md. (H13, L3.)
10. **Service-role separation.** All admin / import paths through a backend or Edge Function using a service-role key on the server side. (H16.)
11. **Versioned, non-destructive migrations.** Replace DROP TABLE IF EXISTS with idempotent migrations. (H3.)
12. **Real RLS regression tests in CI.** Replace the non-functional check_rls.js with Vitest tests that prove anonymous and wrong-workspace clients cannot read or write protected rows. (H7.)
13. **Rebuild and redeploy.** Generate a new bundle so the old hashed asset URL is no longer referenced by the app shell. Purge GitHub Pages / CDN / browser caches; confirm old asset URLs are not reachable.
14. **Rotate exposed operational credentials.** The Supabase publishable key should be rotated as the live RLS was permissive. Notify affected staff and vendors as appropriate.
15. **Verify Supabase RLS live state.** Not only repository scripts — confirm denial of anonymous SELECT / INSERT / UPDATE / DELETE on private tables from a fresh client.

Prevention

- Keep PII and internal business data server-side. The browser should request the minimum necessary data from authenticated APIs.
- Use synthetic demo fixtures. Never use real employee, vendor, asset, financing, or tenant records in client-side mock data. Watermark synthetic fixtures so they cannot be mistaken for real.
- Add a CI artefact scan over dist/ for emails, Korean phone numbers, private domains, staff names, vendor names, Supabase URLs, and project labels. Fail the build on hits.
- Add RLS regression tests proving anonymous clients and wrong-workspace users cannot read, write, update, or delete private rows. Run on every push.
- Classify every data field before implementation: public, internal, confidential, or regulated PII. Drive RLS, logging, retention, and bundling decisions from the classification.

- Treat route guards as UX only. Authorisation must live in the backend, the database policy, or a server-side API layer.
- Pair every RLS policy block with explicit GRANT / REVOKE at the table level. Defence in depth.
- Deploy through CI only; remove ad-hoc deploy scripts from package.json.
- Use Conventional Commits or any structured commit message format. Enforce via PR template or pre-push hook.
- Add SECURITY.md with a defined responsible-disclosure path. Add CODEOWNERS requiring named reviewers on RLS, auth, fixtures, and migrations.
- Keep institutional code in a verified GitHub Organisation tied to the company domain. Personal accounts should be contributors, never owners of institutional repos.
- Register defensive lookalike domains and use OV / EV TLS for institutional systems where appropriate.
- Never load third-party scripts (analytics, fonts, embeds) before consent on a non-public, internal application.

Verification Commands

For internal teams to verify the bundle, the database, and the deployed surface.

```
# Bundle scan – emails, Korean phones, internal labels
rg -n "[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+\.[A-Za-z]{2,}" dist/
rg -n "(010|011|016|017|018|019|02)-[0-9]{3,4}-[0-9]{4}" dist/
rg -n "IGIS|IOTA CFT|PFV|REIT|LP / 대주 / SI|주주대여금|Supabase" dist/

# Bundle scan – extract bundled identifiers (replace path with current build asset)
grep -oE 'https://[a-z0-9]+\.[supabase\.co]' dist/assets/index-*.js | sort -u
grep -oE 'sb_publishable_[A-Za-z0-9]+' dist/assets/index-*.js
grep -oE 'PILOT_ACCESS_CODE[^,;]*|IOTA2026' dist/assets/index-*.js

# Live RLS verification – anonymous client should get 401/empty, not data
SUPA="https://qgrszltduzblpvpqvkqr.supabase.co"
KEY="sb_publishable_..." # current publishable key after rotation
for t in iota_seoul_pilot_members iota_seoul_logs iota_workspace_kpis \
    iota_seoul_log_links iota_seoul_log_stakeholders; do
    curl -s -I "$SUPA/rest/v1/$t?select=*" \
        -H "apikey: $KEY" -H "Range: 0-0" -H "Prefer: count=exact" \
        | grep -iE 'http|content-range'
done

# Network / CORS sanity
curl -s -I -X OPTIONS "$SUPA/rest/v1/iota_seoul_logs" \
    -H "apikey: $KEY" \
    | grep -iE 'allow|access-control'

# Auth posture
curl -s "$SUPA/auth/v1/settings" -H "apikey: $KEY" \
    | python3 -m json.tool | head -20

# HTTP redirect chain (should be HTTPS-only)
curl -sI https://this8369.github.io/IGIS-Fund-Production-DP/ \
    | grep -iE 'http|location'

# Security response headers (should be present after H11 fix)
curl -sI https://iotaseoul.cloud/ \
    | grep -iE 'strict-transport|content-security|x-content|x-frame|referrer-policy'
```


Document Provenance

This merged report combines the original full-disclosure report on the IOTA Seoul static bundle (findings C1–C6, H1–H9, plus all bundle-extracted PII, vendor data, financing labels, external URLs, and source evidence) with red-team findings added during this audit (C7, H10–H16, M1–M11, L1–L4, plus the Live Verification Evidence, Domain & Hosting Posture, GitHub Account & Repository Posture sections, and the extended Project & Financing Labels). All probes used to confirm live exposure were read-only HTTP requests with the publishable key extracted from the deployed bundle. No INSERT, UPDATE, or DELETE was issued against any IGIS system in producing this report.